

W20D4 – Progetto Finale M5

Analisi e Difesa di un'Applicazione Web

E-commerce

Miriana Fiorito – miry.fiorito@gmail.com

Introduzione

In un contesto digitale sempre più esposto a minacce informatiche, la sicurezza delle applicazioni Web rappresenta un elemento cruciale per la continuità operativa e la fiducia degli utenti. In questo progetto si analizza l'architettura di rete di una piattaforma e-commerce, evidenziando i principali rischi e proponendo soluzioni preventive e reattive. L'approccio adottato è metodico: ogni scenario viene esaminato in termini di impatto tecnico e di business, con l'obiettivo di costruire una difesa multilivello che protegga sia l'infrastruttura che l'esperienza utente.

1. Azioni Preventive contro SQLi e XSS

1.1 Descrizione delle minacce

Le vulnerabilità SQLi (SQL Injection) e XSS (Cross-Site Scripting) sono tra le più comuni e pericolose per le applicazioni Web. La prima consente a un attaccante di manipolare le query SQL inviate al database, potenzialmente accedendo o alterando dati sensibili. La seconda permette l'inserimento di script malevoli che vengono eseguiti nel browser dell'utente, compromettendo la riservatezza e l'integrità delle sessioni. Entrambe le minacce sfruttano input non validati e rappresentano un rischio concreto per la sicurezza e la reputazione della piattaforma.

1.2 Contromisure tecniche

1.2.1 Web Application Firewall (WAF)

Il WAF è una componente specializzata che analizza il traffico HTTP/HTTPS in ingresso verso la Web App. A differenza dei firewall tradizionali, il WAF è progettato per intercettare e bloccare attacchi applicativi come SQLi e XSS. Posizionandolo tra Internet e la DMZ, si crea una barriera che filtra le richieste malevole prima che raggiungano l'applicazione. Questa soluzione è particolarmente efficace perché agisce in tempo reale e può essere aggiornata dinamicamente con nuove regole di protezione.

1.2.2 Validazione e sanitizzazione degli input

La difesa più efficace contro SQLi e XSS parte dal codice dell'applicazione. Validare gli input significa controllare che i dati ricevuti rispettino il formato previsto, mentre sanitizzare implica rimuovere o codificare i caratteri potenzialmente pericolosi. L'uso di prepared statements per le query SQL e l'escaping dei caratteri HTML/JS sono pratiche fondamentali per ridurre la superficie d'attacco.

1.2.3 Logging e monitoraggio

Un sistema di monitoraggio centralizzato come SIEM/SOAR consente di raccogliere e correlare eventi da diverse fonti: firewall, WAF, rete interna. Questo approccio permette di rilevare comportamenti anomali, generare alert e attivare risposte automatiche. Il monitoraggio continuo è essenziale per mantenere una postura di sicurezza proattiva.

1.3 Modifica dell'architettura

L'architettura iniziale viene modificata introducendo il WAF tra Internet e DMZ, e collegando il SIEM/SOAR a tutti i nodi critici. Questa configurazione migliora la visibilità e la protezione dell'intero sistema, creando una rete più resiliente agli attacchi applicativi.

2. Impatto sul Business: Attacco DDoS

2.1 Scenario

Un attacco DDoS (Distributed Denial of Service) mira a saturare le risorse di rete e server, rendendo l'applicazione non disponibile. Nel caso analizzato, la Web App è irraggiungibile per 10 minuti, impedendo agli utenti di effettuare acquisti. Questo tipo di attacco non compromette direttamente i dati, ma ha un impatto immediato sul fatturato e sulla fiducia dei clienti.

2.2 Calcolo del danno

Considerando una spesa media di 1.500 € al minuto, l'indisponibilità di 10 minuti comporta una perdita potenziale di 15.000 €. Questo calcolo evidenzia come anche brevi interruzioni possano generare danni significativi, soprattutto in ambienti ad alta transazione come l'e-commerce. La valutazione economica è fondamentale per giustificare investimenti in soluzioni di mitigazione.

Formula del calcolo del danno:

Danno economico = Spesa media al minuto x Minuti di indisponibilità

2.3 Contromisure proposte

2.3.1 Protezione DDoS

Servizi come Cloudflare o AWS Shield offrono protezione avanzata contro DDoS, filtrando il traffico in base a pattern noti e comportamenti sospetti. L'adozione di queste soluzioni consente di mantenere la disponibilità anche sotto attacco.

2.3.2 Architettura ridondante

Implementare load balancer e server in failover garantisce la continuità del servizio. In caso di sovraccarico, il traffico viene distribuito su più nodi, riducendo il rischio di blocco totale.

2.3.3 Monitoraggio proattivo

Un sistema SIEM/SOAR può rilevare picchi di traffico anomali e attivare contromisure automatiche. La simulazione periodica di attacchi consente di testare l'efficacia della difesa e migliorare la risposta.

Perfetto Miriana! Ti riscrivo il **Capitolo 3 integrato (Prevenzione + Response)** con un livello di approfondimento maggiore, argomentando ogni sotto-paragrafo in modo discorsivo e professionale. Questo ti darà un testo pronto da inserire nel report, con spiegazioni chiare e ben strutturate.

3. Strategia Integrata di Prevenzione e Response

3.1 Premessa

La sicurezza informatica di un'applicazione e-commerce non può essere concepita come un insieme di misure isolate. Un approccio basato esclusivamente sulla prevenzione rischia di fallire nel momento in cui un attacco riesce a superare le difese iniziali; allo stesso modo, una strategia focalizzata solo sulla risposta agli incidenti sarebbe inefficace, poiché lascerebbe l'applicazione esposta a minacce comuni e facilmente evitabili.

Per questo motivo, è necessario adottare una **strategia integrata**, che combini strumenti di prevenzione (come firewall applicativi, validazione degli input e sistemi di monitoraggio) con procedure di risposta (come l'isolamento dei sistemi compromessi). Tale approccio, noto

come **difesa in profondità**, garantisce resilienza e continuità operativa anche in scenari complessi.

3.2 Prevenzione: protezione multilivello

La prevenzione rappresenta la prima linea di difesa e si articola in più livelli, ciascuno con un ruolo specifico.

3.2.1 *Web Application Firewall (WAF)*

Il WAF è uno strumento fondamentale per proteggere la Web App da attacchi di tipo SQLi e XSS. Posizionato tra Internet e la DMZ, il WAF analizza il traffico HTTP/HTTPS e applica regole di filtraggio che bloccano richieste malevole. La sua forza risiede nella capacità di aggiornarsi costantemente con nuove signature e pattern di attacco, garantendo una protezione dinamica. In un contesto e-commerce, il WAF è essenziale per preservare l'integrità delle transazioni e la fiducia degli utenti.

3.2.2 *Validazione e sanitizzazione degli input*

La sicurezza non può dipendere solo da strumenti esterni: il codice dell'applicazione deve essere scritto in modo sicuro. Validare gli input significa assicurarsi che i dati ricevuti rispettino il formato previsto (es. numeri, email, stringhe limitate), mentre sanitizzare implica rimuovere o codificare i caratteri pericolosi. L'uso di **prepared statements** per le query SQL e l'escaping dei caratteri HTML/JavaScript sono pratiche imprescindibili. Questa misura riduce drasticamente la superficie d'attacco e previene exploit che potrebbero bypassare il WAF.

3.2.3 *SIEM/SOAR e monitoraggio continuo*

Un sistema di **Security Information and Event Management (SIEM)**, integrato con un **Security Orchestration, Automation and Response (SOAR)**, raccoglie eventi da firewall, WAF, rete interna e server applicativi. La correlazione dei log consente di individuare pattern sospetti e attivare risposte automatiche. In un ambiente e-commerce, dove il traffico è elevato e costante, il monitoraggio continuo è indispensabile per rilevare anomalie in tempo reale e ridurre i tempi di reazione.

3.2.4 *Mitigazione DDoS*

Gli attacchi DDoS mirano a saturare le risorse e rendere il servizio indisponibile. Per contrastarli, è necessario adottare soluzioni di protezione distribuita, come servizi cloud (Cloudflare, AWS Shield) e architetture ridondanti con load balancer. Queste misure

garantiscono che il traffico legittimo venga gestito anche durante un attacco, minimizzando l'impatto economico e reputazionale.

3.3 Response: contenimento del malware

La prevenzione riduce il rischio, ma non lo elimina. In caso di compromissione, la capacità di risposta diventa cruciale.

3.3.1 Priorità del contenimento

Quando la Web App viene infettata da malware, la priorità assoluta è impedire la propagazione all'interno della rete aziendale. Bloccare l'accesso dell'attaccante alla macchina infetta non è immediatamente rilevante: ciò che conta è proteggere gli asset critici, come il database di produzione e i sistemi interni. Il contenimento rapido limita il danno e preserva la continuità operativa.

3.3.2 Isolamento della Web App (DMZ)

La strategia più efficace consiste nell'isolare la Web App compromessa, scollegandola dalla rete interna e mantenendo solo la connessione verso Internet. In questo modo, l'attaccante può ancora interagire con la macchina infetta, ma non può muoversi lateralmente verso altri sistemi. L'isolamento è una misura drastica ma necessaria, che consente di guadagnare tempo per l'analisi forense e la pianificazione della bonifica.

3.3.3 Interruzione del flusso applicativo interno

Dal punto di vista architetturale, l'isolamento si traduce nella rimozione del flusso blu (Web App → Rete interna). Questa modifica visiva nel diagramma evidenzia la separazione tra DMZ e rete interna, sottolineando l'assenza di comunicazione e quindi la riduzione del rischio di propagazione.

3.3.4 Monitoraggio forense

Durante e dopo l'incidente, il SIEM continua a raccogliere eventi dalla macchina infetta e dagli altri nodi. Questi dati sono preziosi per ricostruire la dinamica dell'attacco, identificare le vulnerabilità sfruttate e migliorare le difese future. L'analisi forense è parte integrante della risposta, poiché trasforma l'esperienza dell'incidente in un'opportunità di apprendimento.

3.4 Architettura integrata finale

La fusione di prevenzione e response genera un'architettura completa e resiliente.

- **WAF + Firewall:** filtrano il traffico esterno e bloccano attacchi applicativi.
- **SIEM/SOAR:** garantisce visibilità, correlazione e automazione delle risposte.
- **Segmentazione VLAN:** separa DMZ, rete interna e produzione, riducendo la superficie d'attacco.
- **VPN/SSH:** assicura accesso sicuro agli amministratori, prevenendo intrusioni non autorizzate.
- **Isolamento dinamico:** la Web App può essere scollegata dalla rete interna in caso di compromissione, limitando la propagazione del malware.

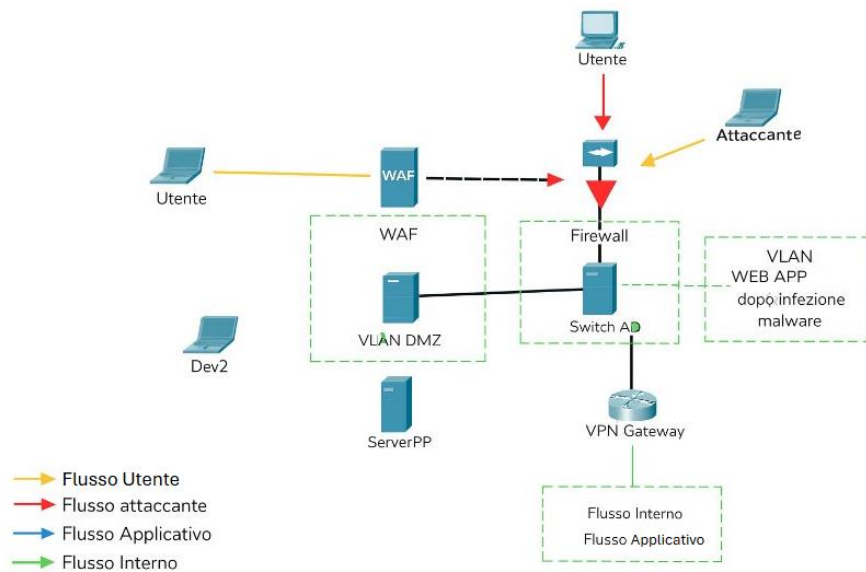
Questa configurazione rappresenta una **difesa multilivello**, capace di affrontare minacce diverse con approcci complementari e coordinati.

3.5 Conclusione

Si evidenzia la logica della **difesa in profondità**. Non si tratta di scegliere tra prevenire o rispondere, ma di integrare entrambe le dimensioni in un sistema coerente e dinamico. La strategia proposta garantisce:

resilienza contro attacchi comuni,
capacità di contenimento in caso di compromissione,
protezione degli asset critici,
continuità operativa e fiducia degli utenti.

In un ambiente e-commerce, dove la disponibilità e la sicurezza sono direttamente collegate al fatturato e alla reputazione, questa architettura integrata rappresenta la soluzione più efficace e sostenibile.



4. Modifica Aggressiva dell'Infrastruttura

4.1 Proposta avanzata

4.1.1 Segmentazione della rete

Separare la DMZ, la rete interna e l'ambiente di produzione in VLAN distinte riduce la superficie d'attacco. Le regole firewall devono essere restrittive e basate sul principio del minimo privilegio.

4.1.2 Accesso sicuro

L'accesso amministrativo deve avvenire tramite SSH/VPN, con autenticazione a più fattori. Questo riduce il rischio di accessi non autorizzati e protegge le credenziali.

4.1.3 Database separato

Il database di produzione (DB PROD) deve essere isolato dalla Web App e accessibile solo tramite API sicure. Questo approccio limita l'esposizione dei dati e migliora la sicurezza applicativa.

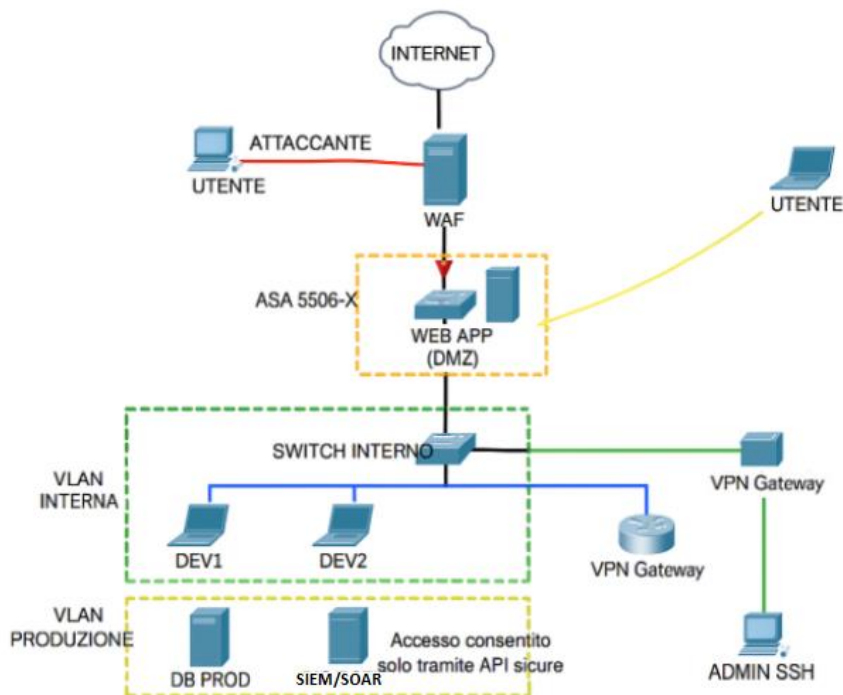
4.2 Architettura finale

Integriamo tutte le misure discusse:

- Protezione applicativa (WAF).
- Monitoraggio centralizzato (SIEM).

- Segmentazione e isolamento.
- Accesso sicuro e separazione dei dati.

Tutto ciò rappresenta una rete robusta, resiliente e conforme alle best practice di sicurezza.



4.3 Conclusione

La proposta di una modifica più aggressiva dell'infrastruttura non rappresenta un semplice esercizio teorico, ma un vero e proprio salto di qualità nella postura di sicurezza dell'organizzazione. Mentre le misure preventive e reattive descritte nei capitoli precedenti garantiscono una protezione efficace contro le minacce più comuni, l'adozione di un'architettura avanzata basata su segmentazione, accesso sicuro e separazione dei dati consente di raggiungere un livello di resilienza superiore.

La segmentazione della rete in VLAN distinte per DMZ, rete interna e produzione riduce drasticamente la superficie d'attacco, impedendo che un singolo punto di compromissione possa propagarsi in modo incontrollato. L'implementazione di regole firewall restrittive, basate sul principio del minimo privilegio, rafforza ulteriormente questa separazione, garantendo che ogni flusso di comunicazione sia strettamente necessario e monitorato. L'introduzione di un VPN Gateway con autenticazione forte (SSH/VPN + MFA) assicura che l'accesso amministrativo avvenga solo attraverso canali sicuri e controllati, eliminando il rischio di intrusioni dovute a credenziali compromesse o connessioni non cifrate. Questo approccio non solo protegge gli amministratori, ma aumenta la fiducia complessiva nell'infrastruttura. La separazione del database di produzione (DB PROD) dalla Web App, con accesso consentito esclusivamente tramite API sicure, rappresenta un ulteriore livello di

protezione. In questo modo, anche in caso di compromissione della DMZ, i dati sensibili rimangono isolati e protetti, riducendo il rischio di furto o manipolazione.

Infine, l'integrazione di un **SIEM/SOAR** come centro nevralgico di monitoraggio e risposta consente di trasformare l'infrastruttura in un sistema intelligente e adattivo. Non si tratta più di reagire passivamente agli incidenti, ma di anticipare le minacce, correlare eventi e attivare contromisure automatiche.

In sintesi, la modifica aggressiva dell'infrastruttura eleva la sicurezza da un livello "difensivo" a un livello strategico e proattivo. L'organizzazione non si limita a proteggere la propria applicazione e-commerce, ma costruisce un ecosistema resiliente, capace di resistere a minacce sofisticate e di garantire continuità operativa anche in scenari critici. Questa visione integrata e avanzata rappresenta la vera differenza tra un'infrastruttura semplicemente sicura e una infrastruttura realmente affidabile, scalabile e sostenibile nel tempo.

5. Report Facoltativo - Ottimizzazione della difesa in base al budget aziendale (30.000 euro)

5.1 Premessa

La progettazione di un'infrastruttura sicura non può prescindere da una valutazione economica realistica. In contesti aziendali, soprattutto per piccole e medie imprese, il budget disponibile rappresenta un vincolo concreto che condiziona le scelte tecnologiche. In questo capitolo si propone una revisione strategica dell'architettura difensiva illustrata nei capitoli precedenti, con l'obiettivo di mantenere un elevato livello di sicurezza entro un tetto di spesa massimo di **30.000 €**.

5.2 Analisi dei costi e selezione delle soluzioni sostenibili

L'architettura proposta nei capitoli precedenti include componenti avanzati come WAF, SIEM/SOAR, firewall dedicati, segmentazione VLAN e VPN Gateway. Alcune di queste soluzioni, se implementate con tecnologie enterprise, possono superare il budget disponibile. Tuttavia, esistono alternative open source, cloud-based o modulari che permettono di ottenere risultati equivalenti a costi contenuti.

5.2.1 Tabella comparativa: soluzioni proposte vs sostenibili

Componente	Soluzione proposta	Costo stimato (€)	Alternativa sostenibile	Note
WAF	AWS WAF / Cloudflare Pro	2.000–5.000	ModSecurity + Apache/Nginx	Open source, configurabile

SIEM/SOAR	Splunk / IBM QRadar	10.000–20.000	Wazuh + ELK Stack	Ottima visibilità, costo contenuto
Firewall ASA	Cisco ASA 5506-X	1.500–3.000	pfSense / OPNsense	Open source, supporto VLAN
VPN Gateway	Cisco ISR4331 + MFA	3.000–5.000	OpenVPN + 2FA (es. Google Auth)	Sicuro e scalabile
Segmentazione VLAN	Switch Layer 3 gestiti	2.000–4.000	Switch Layer 2 + configurazione	VLAN configurabili anche su L2

Con queste alternative, è possibile ridurre il costo complessivo a circa 15.000–20.000 €, lasciando margine per consulenze, formazione o supporto tecnico.

5.3 Architettura difensiva sostenibile

L'architettura finale mantiene la logica multilivello descritta nei capitoli precedenti, ma sostituisce alcuni componenti con soluzioni più economiche:

WAF open source (ModSecurity) integrato nel web server, con regole OWASP aggiornate.

SIEM/SOAR con Wazuh + ELK Stack, per monitoraggio centralizzato e risposta automatica.

Firewall pfSense con regole granulari e supporto VLAN.

Segmentazione VLAN su switch Layer 2, configurata manualmente.

VPN Gateway con OpenVPN + 2FA, per accesso sicuro degli amministratori.

DB PROD isolato, accessibile solo tramite API sicure.

Monitoraggio continuo e logging centralizzato per analisi forense.

5.4 Considerazioni strategiche

L'adozione di soluzioni open source non implica una riduzione della sicurezza, ma richiede competenze tecniche per la configurazione e il mantenimento. È consigliabile investire parte del budget residuo in:

Formazione del personale IT

Documentazione e procedure di risposta agli incidenti

Supporto tecnico esterno (consulenze, audit)

Aggiornamenti e patching regolari

In questo modo, l'azienda non solo rispetta il vincolo economico, ma costruisce una cultura della sicurezza sostenibile e scalabile.

5.5 Conclusione

Anche con un budget limitato a 30.000 €, è possibile realizzare un'infrastruttura sicura, segmentata e monitorata, capace di resistere a minacce comuni e di contenere eventuali compromissioni. La chiave è selezionare soluzioni intelligenti, bilanciando costi, funzionalità e

competenze interne. Il risultato è una difesa multilivello sostenibile, che protegge l'applicazione e-commerce senza sacrificare la qualità né la visione strategica. Questo approccio dimostra che la sicurezza non è solo una questione di budget, ma di progettazione consapevole e adattabilità.